

Ataque a un datacenter con ns-3.

1. Resumen

En este documento veremos como, utilizando la herramienta ns-3 y un gemelo digital de un data center conectado a un chatbot, podemos realizar un ataque de DoS o DDoS con el envío de paquetes UDP.

2. ¿Qué es un gemelo digital?

- Gemelo digital:

Un gemelo digital es una copia 1 a 1 de un sistema que permite simularlo sin la necesidad de realizar las acciones en la estructura real. Permite hacer testbench como este para observar como se comporta ante diferentes ataques.

3. Objetivo del Reto.

El objetivo principal de este reto es simular el comportamiento de la red cuando se realiza un ataque DoS a una infraestructura, en este caso, un datacenter.

Con esto obtendremos una métrica de la resistencia ante este tipo de ataques, así como poder analizar alguna solución o mitigación posible.

4. Diseño de la topología de red.

La red escogida (Spine-Leaf) es la más común dentro de este tipo de infraestructura debido a su fácil escalabilidad, robustez, mitigación de cuellos de botellas, capacidad de comunicación server-to-server, entre otras.

La parte central, el Spine, tiene una velocidad de 40Gbps con un retraso de 2 μ s.

El resto de nodos, Leaf y servidores, tienen una velocidad de conexión de 10Gbps, con un retraso de 5 μ s.

En cuanto a las IPs, nos encontramos con varias de ellas dentro del código.

Spine			
192.168.1.0/24	192.168.2.0/24	192.168.3.0/24	192.168.4.0/24
Leaf			
10.1.1.0/30	10.1.2.0/30	10.1.3.0/30	10.1.4.0/30
Attacker			
172.16.1.0/24			

5. El entorno de amenaza

Por medio de remote code execution (RCE), a través de un exploit con un chatbot, un atacante ha obtenido acceso directo a la red, y busca eliminar el acceso al centro. Por ello, apunta a realizar un UDP flood a una tasa de 8Gbps dirigida al tercer servidor.

En la simulación podemos observar cómo, entre el tiempo 0.0s y 1.0s, se inicializa la red. Entre $t = 2.0s$ y $t = 15.0s$, existe un tráfico legítimo, de usuarios haciendo peticiones. Por último, desde $t = 5.0s$ a $t = 10.0s$, se realiza la inyección de paquetes.

6. Análisis de resultados

Podemos observar 2 fases:

1) Fase de Normalidad.

Durante los primeros segundos, ocurre un intercambio legítimo de mensajes echo entre el servidor 0 y el servidor 3, con latencias en el rango de los ms.

2) Fase de Ataque.

Se puede observar como la red se degrada inmediatamente, al ser una comunicación de 8 Gbps, se satura el 80% de la red, siendo esta situación muy cercana al límite teórico de la red. De esta manera, se llenan por completo los buffers de red del switch que lleva al servidor 0, impidiendo la comunicación previa de mensajes echo del servidor 3.

Podemos observar cómo se produce un DoS efectivo, impidiendo el contacto entre el servidor 0 y cualquier otro sitio.

7. Propuestas de mitigación.

Lo primero de todo es eliminar el exploit del chat-bot, puesto que es la entrada directa para realizar todo el ataque. Se podría lograr haciendo que los nodos del chatbot solo tengan permitido el tráfico saliente hacia el exterior, impidiendo así el acceso a las redes de producción.

Por otro lado, implementar una limitación de tasa para que el segmento UDP proveniente del chatbot tenga un máximo estricto, muy por debajo de la capacidad total del sistema.

Para terminar, realizar un despliegue de sistemas para detección de intrusos, monitoreando picos anómalos de entrada en el sistema, activando sistemas de alarma y aislando el switch en específico.

8. Conclusión.

Con la realización de este trabajo, nos hemos percatado de la importancia real que tienen los gemelos digitales en relación con la ciberseguridad. Tener la capacidad de realizar ataques realistas en sistemas complejos con tan solo un ordenador para simularlo permite tener una justificación a las diferentes implementaciones de seguridad propuestas, así como la posibilidad de probar diferentes configuraciones de las mismas para obtener el resultado más óptimo.

Por otro lado, nos percatamos de que las herramientas de ciberseguridad son principalmente defensivas y de planificación, siendo la parte más eficaz dentro de la defensa de una infraestructura compleja, y luego el trabajo más del día a día es la prevención de ataques que, aunque poco probables, siguen siendo un objetivo valioso para los atacantes.

9. Documentos extra útiles.

En el documento titulado “datacenter_twin.cc” nos podremos encontrar con el código utilizado para realizar la prueba. Para la generación de este archivo fue utilizada la Inteligencia Artificial Gemini, tanto para su generación como para su entendimiento.

En el documento titulado “simulation.txt” nos encontramos con parte de la salida de la simulación realizada, pudiendo observar los últimos segundos del ataque, así como después la finalización del ataque.

